

Glossary

TCP: Transmission Control Protocol is the method used to transfer information between two connected computers over a network or the Internet. In a TCP implementation, the protocol divides the information into smaller packets, and also at the same time ensures that the packets reach the other side safely.

UDP: User Datagram Protocol is a connectionless transport protocol, which means that you do not need to have a connection established between the host and the remote machine before starting transfer of data.

ICQ, for instance, is an application that uses the UDP protocol. UDP, however, doesn't ensure that the packets reach easily, though it is faster.

ICMP: Internet Control Message Protocol carries control messages that are used to acknowledge and respond to connections. For example, the ping command uses this protocol.

IGMP: The Internet Group Management Protocol is an extension of the IP protocol and a standard for IP multicasting. It is used to inform local routers about the presence of a member of a multicast group. If a host is part of a multicast group, then it is also more prone to IGMP flooding.

Packet sniffer: Packet sniffing refers to monitoring data that is passed over a network. You have specific software that allow you to sniff the packets that travel and retrieve information from it.

RATs/Backdoors: Remote Administration Tools are a method of controlling remote machines using the IP address. Trojans such as SubSeven and BackOffice are RATs in that sense as you can control a remote machine if the Trojan is installed in it.

Normally, these Trojans have a server part and a client part. The server is installed in the remote machine and listens on a particular port. Using the client, you can connect to the server on that port, and then control the machine in any way you want. You can even enable packet sniffing using some RATs.

DoS/Nukes/Flooding: Denial of Service attacks prevent a target machine from accessing a network resource. A simple form of a DoS attack is by sending large packets of data to a single machine, thereby making it unstable or even crashing it.

access the Internet, prevent malicious scripts or controls from stealing information or uploading files and prevent Trojans and other backdoors from running as servers.

Port scans: The good thing with most of the firewalls we tested was that they didn't show up any ports as open in the Nmap and Retina scans. If at all there was an open port, it was port 139, which is related to sharing files over networks. The one software that showed up more open ports was eSafe desktop. It showed port 139, port 6699 (the port used by the Napster application), and other such ports as open. BlackICE Defender was the most informative in terms of identifying the port scan attempts, and even recognised the Nmap scans and the actual commands that were being sent.

Intrusion attacks: The differences came up when we tried the application level or OS level exploits. Firewalls such as Sygate, Tiny and eSafe showed up the blue screen momentarily when we tried an IGMP flooding. Others such as Norton Personal Firewall, ZoneAlarm and NeoWatch became unstable with packet flooding attacks. However, such intrusion detection attempts had no effect on ZoneAlarm Pro, and the Network Associates products—McAfee Personal Firewall and PGP Desktop Security. These two, in fact, managed to do quite a bit of load balancing by ignoring such attacks totally, to the extent that we did not even come to know that we were being flooded with packets. We faced no problem with exploits targeted at software such as ICQ or mIRC, and the firewalls were able to ward them off easily.

Malicious Web sites: Detection of malicious ActiveX controls, scripts or Java

applets was a grey area with all the firewalls (except Norton to some extent). Sites manage to exploit the vulnerabilities in Internet Explorer, Outlook Express and other software to steal information or upload files. Therefore, even if firewalls do not recognise such malicious sites, they should be able to warn you when data is being retrieved or written to your machine.

We were able to easily upload a .hta file, which runs a 'Hello World' message, to the Test Bench without the firewalls detecting any warning. Only Norton stopped the loading of a malicious Java applet on



PGP Desktop wards off most intrusion attempts

another site. We were also able to configure eSafe Desktop to block the .hta file from being uploaded. eSafe employs the method of selective file-sharing or 'sandbox'. So for each application, you can specify the directory rights (or even file rights) in terms of read, write, execute, delete, etc. For instance, you can specify that Internet Explorer will have no read rights over the Windows Desktop and System directory,

Scanning through Web Sites

Before you start the firewall hunt, you can get your machine diagnosed online using Web sites that offer this service. These Web sites normally scan your machine using some commercial port scanner to see if there are any ports open and report the same to you.

Remember though, that if you are scanning from a dial-up access, this may take some time. And you cannot be beyond a gateway or a proxy which hides your IP address if you want your machine scanned.

Symantec's site even offers to scan your machine for Trojans and analyses the privacy features of your computer.

The ASP site of Network Associates McAfeeasap.com, also gives a free trial to check your system for vulnerabilities using PGP CyberCop scanner. The only problem here is that you have to register first before availing of this facility. There are other Web sites which offer a paid service, and this is more useful if you have your own Web site or domain name. Some of the sites offering audit through the Web are:

www.symantec.com
www.grc.com
www.mcafeeasap.com
www.securityspace.com
www.automatedscanning.com